Task 1.1 – Thiết kế dữ liệu Người dùng & Xác thực

Dự án: ShopFlow – Nền tảng Thương mại Điện tử B2C | **Trạng thái:** Ready for Review

Thuộc tính	Giá trị
Dự án	ShopFlow – Nền tảng thương mại điện tử B2C
Giai đoạn	Sprint 1 – Thiết kế & thiết lập nền tảng
Work item	Task 1.1
Yêu cầu liên quan	CUS-01 (Đăng ký / Đăng nhập); CUS-05 (Lưu thông tin cá nhân)
Phiên bản	1.0 (Ngày cập nhật: 10/09/2026)

1. Mục tiêu

Tài liệu xác định mô hình dữ liệu cho các nhóm nghiệp vụ xác thực và quản lý người dùng:

1. Lưu trữ tài khoản người dùng, phân quyền vai trò (Role-Based Access Control – RBAC Baseline).
2. Lưu trữ mật khẩu băm an toàn tuân thủ Security Baseline của hệ thống.
3. Quản lý vòng đời token/OTP khôi phục mật khẩu (Reset Password Flow).
4. Lưu trữ thông tin hồ sơ cá nhân và sổ địa chỉ giao hàng đa kênh của khách hàng.

2. Phạm vi và nguồn thiết kế

2.1 Yêu cầu từ PRD

- **CUS-01 – Đăng ký / Đăng nhập:** Xác thực qua Email / Mật khẩu hoặc OTP. Lưu session an toàn với JWT/Cookie. Hỗ trợ khôi phục mật khẩu.
- **CUS-05 – Lưu thông tin cá nhân:** Quản lý thông tin hồ sơ (Họ tên, SĐT, Email); lưu danh sách nhiều địa chỉ giao hàng để tái sử dụng khi checkout.

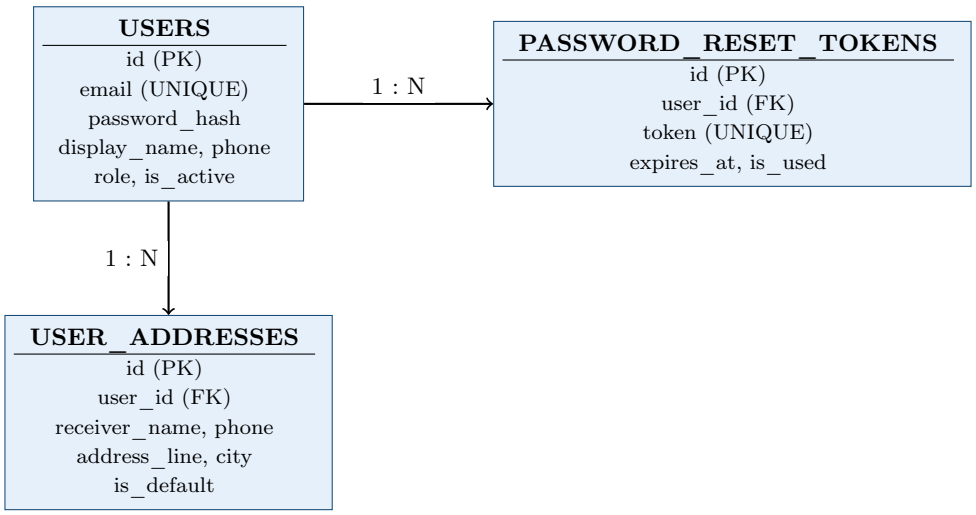
2.2 Thành phần schema và Security Baseline liên quan

- **SEC-PASS-01 & SEC-PASS-02:** Database chỉ lưu `password_hash` được mã hóa bằng BCrypt (strength 10), tuyệt đối không lưu plain text.
- **SEC-AUTH-01 & SEC-AUTH-03:** Hệ thống sử dụng Server-side Session qua HttpOnly cookie. API không nhận `customerId` từ request body mà xác thực trực tiếp qua Session.
- **SEC-PASS-04:** Token reset password có thời hạn, chỉ sử dụng một lần và tự động vô hiệu hóa sau khi đổi mật khẩu thành công.

3. Quyết định thiết kế

ID	Quyết định	Lý do
DD-01	Sử dụng `email` làm định danh duy nhất (Unique Index) cho việc đăng nhập.	Đảm bảo tính duy nhất của tài khoản và phục vụ luồng khôi phục mật khẩu qua email.
DD-02	Băm mật khẩu bằng thuật toán BCrypt (`password_hash`).	Tuân thủ quy chuẩn bảo mật SEC-PASS-01/02, chống rò rỉ thông tin mật khẩu.
DD-03	Tách riêng danh sách địa chỉ giao hàng ra bảng `user_addresses` (1:N với `users`).	Cho phép một khách hàng lưu nhiều địa chỉ và chọn địa chỉ mặc định khi checkout.
DD-04	Quản lý token reset password bằng bảng `password_reset_tokens` độc lập.	Kiểm soát thời gian hết hạn (`expires_at`), cờ vô hiệu hóa (`is_used`) và audit trail.

4. Mô hình quan hệ (ERD Diagram)



5. Đặc tả chi tiết các bảng

5.1 Đặc tả bảng `users`

Bảng trung tâm lưu trữ thông tin tài khoản và định danh người dùng.

Field	Kiểu dữ liệu	Constraint	Mô tả
`id`	BIGSERIAL	PK	Khóa chính tự tăng
`email`	VARCHAR(255)	NOT NULL, UNIQUE	Email đăng nhập hệ thống
`password_hash`	VARCHAR(255)	NOT NULL	Mật khẩu mã hóa BCrypt (SEC-PASS-01)
`display_name`	VARCHAR(255)	NOT NULL	Họ và tên hiển thị người dùng
`phone`	VARCHAR(20)	nullable	Số điện thoại liên hệ
`role`	VARCHAR(30)	NOT NULL, DEFAULT 'CUSTOMER'	Vai trò: `CUSTOMER`, `WAREHOUSE`, `SHOP_OWNER`
`is_active`	BOOLEAN	NOT NULL, DEFAULT TRUE	Trạng thái tài khoản (Active/Banned)
`created_at`	TIMESTAMPTZ	NOT NULL	Thời điểm tạo tài khoản
`updated_at`	TIMESTAMPTZ	NOT NULL	Lần cập nhật gần nhất

5.2 Đặc tả bảng `password_reset_tokens`

Lưu trữ token/OTP phục vụ tính năng khôi phục mật khẩu.

Field	Kiểu dữ liệu	Constraint	Mô tả
`id`	BIGSERIAL	PK	Khóa chính tự tăng
`user_id`	BIGINT	FK, NOT NULL	Tham chiếu tới `users.id`
`token`	VARCHAR(255)	NOT NULL, UNIQUE	Mã token xác thực ngẫu nhiên an toàn
`expires_at`	TIMESTAMPTZ	NOT NULL	Thời điểm hết hạn token (SEC-PASS-04)
`is_used`	BOOLEAN	NOT NULL, DEFAULT FALSE	Cờ đánh dấu token đã được dùng
`created_at`	TIMESTAMPTZ	NOT NULL	Thời điểm sinh token

5.3 Đặc tả bảng `user_addresses`

Lưu sổ địa chỉ giao hàng của từng khách hàng (CUS-05).

Field	Kiểu dữ liệu	Constraint	Mô tả
id	BIGSERIAL	PK	Khóa chính tự tăng
user_id	BIGINT	FK, NOT NULL	Tham chiếu tới users.id
receiver_name	VARCHAR(255)	NOT NULL	Tên người nhận hàng
receiver_phone	VARCHAR(20)	NOT NULL	SĐT người nhận hàng
address_line	VARCHAR(500)	NOT NULL	Địa chỉ chi tiết (Số nhà, đường)
district	VARCHAR(100)	nullable	Quận / Huyện
city	VARCHAR(100)	NOT NULL	Tỉnh / Thành phố
is_default	BOOLEAN	NOT NULL, DEFAULT FALSE	Đánh dấu địa chỉ mặc định khi checkout
created_at	TIMESTAMPTZ	NOT NULL	Thời điểm tạo record
updated_at	TIMESTAMPTZ	NOT NULL	Lần cập nhật gần nhất

6. Vòng đời Token Khôi phục Mật khẩu (Reset Password Lifecycle)



Quy tắc vận hành:

- **Khởi tạo & Thời hạn:** Khi người dùng gửi yêu cầu quên mật khẩu qua API `POST /auth/forgot-password`, hệ thống sinh token xác thực ngẫu nhiên, lưu vào `password_reset_tokens` kèm mốc thời hạn `expires_at` (mặc định 15 phút) và cờ `is_used = FALSE`.
- **Sử dụng một lần (Single-use):** Khi người dùng đặt lại mật khẩu thành công qua API `POST /auth/reset-password`, hệ thống cập nhật mật khẩu mới đồng thời chuyển `is_used = TRUE` để vô hiệu hóa token ngay lập tức (SEC-PASS-04).
- **Kiểm tra tính hợp lệ:** Mọi yêu cầu xác thực chứa token có cờ `is_used = TRUE` hoặc có mốc thời gian hiện tại vượt quá `expires_at` đều bị từ chối với mã lỗi `400 Bad Request`.

7. Index đề xuất

Bảng	Index	Mục đích
users	UNIQUE INDEX idx_users_email (email)	Tối ưu tốc độ truy vấn đăng nhập theo Email và chống trùng lặp.
password_reset_tokens	UNIQUE INDEX idx_tokens_token (token)	Tra cứu nhanh token xác thực khi khôi phục mật khẩu.
password_reset_tokens	INDEX idx_tokens_user_id (user_id)	Lấy lịch sử yêu cầu reset password của người dùng.
user_addresses	INDEX idx_addresses_user_id (user_id)	Tải nhanh danh sách sổ địa chỉ tại trang Hồ sơ và Checkout.

8. Script Migration SQL (Flyway)

```sql
-- V1_1__create_users_auth_and_addresses.sql

CREATE TABLE users (
    id BIGSERIAL PRIMARY KEY,
    email VARCHAR(255) NOT NULL,
    password_hash VARCHAR(255) NOT NULL,
    display_name VARCHAR(255) NOT NULL,
    phone VARCHAR(20),
    role VARCHAR(30) NOT NULL DEFAULT 'CUSTOMER',
```

```
    is_active BOOLEAN NOT NULL DEFAULT TRUE,
    created_at TIMESTAMPTZ NOT NULL DEFAULT CURRENT_TIMESTAMP,
    updated_at TIMESTAMPTZ NOT NULL DEFAULT CURRENT_TIMESTAMP,
    CONSTRAINT uq_users_email UNIQUE (email)
);

CREATE TABLE password_reset_tokens (
    id BIGSERIAL PRIMARY KEY,
    user_id BIGINT NOT NULL,
    token VARCHAR(255) NOT NULL,
    expires_at TIMESTAMPTZ NOT NULL,
    is_used BOOLEAN NOT NULL DEFAULT FALSE,
    created_at TIMESTAMPTZ NOT NULL DEFAULT CURRENT_TIMESTAMP,
    CONSTRAINT fk_tokens_user FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE
        CASCADE,
    CONSTRAINT uq_tokens_token UNIQUE (token)
);

CREATE TABLE user_addresses (
    id BIGSERIAL PRIMARY KEY,
    user_id BIGINT NOT NULL,
    receiver_name VARCHAR(255) NOT NULL,
    receiver_phone VARCHAR(20) NOT NULL,
    address_line VARCHAR(500) NOT NULL,
    district VARCHAR(100),
    city VARCHAR(100) NOT NULL,
    is_default BOOLEAN NOT NULL DEFAULT FALSE,
    created_at TIMESTAMPTZ NOT NULL DEFAULT CURRENT_TIMESTAMP,
    updated_at TIMESTAMPTZ NOT NULL DEFAULT CURRENT_TIMESTAMP,
    CONSTRAINT fk_addresses_user FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE
        CASCADE
);

CREATE INDEX idx_tokens_user_id ON password_reset_tokens(user_id);
CREATE INDEX idx_addresses_user_id ON user_addresses(user_id);
```

9. Acceptance Criteria

☐ Bảng `users` thiết lập trường `password_hash` lưu mật khẩu băm BCrypt (SEC-PASS-01).

☐ Tuyệt đối không tồn tại bất kỳ trường lưu mật khẩu chưa mã hóa (plain text) nào.

☐ Bảng `password_reset_tokens` quản lý token reset mật khẩu kèm thời gian hết hạn (`expires_at`) và cờ `is_used`.

☐ Mô hình hỗ trợ lưu danh sách nhiều địa chỉ giao hàng (`user_addresses`) có đánh dấu địa chỉ mặc định (`is_default`).

☐ Đã tạo đầy đủ các Index tối ưu cho truy vấn đăng nhập, reset password và lấy sổ địa chỉ.

10. Tài liệu tham chiếu

- PRD B2C: Mục CUS-01 (Đăng ký/Đăng nhập) và CUS-05 (Lưu thông tin cá nhân).
- Task 1.8 Document: Security baseline (SEC-PASS-01 đến SEC-PASS-04).
- Azure DevOps Markdown guidance: https://learn.microsoft.com/en-us/azure/devops/project/wiki/markdown-guidance

11. Lịch sử thay đổi

Phiên bản	Ngày	Nội dung
1.0	10/09/2026	Thiết kế ban đầu cho dữ liệu Người dùng, Xác thực & Địa chỉ theo PRD và Security Baseline